ESEN

CIBERSEGURIDAD

Guía del Estudiante

Análisis de Impacto en el Negocio (BIA)

Del levantamiento con los dueños de los procesos al informe ejecutivo

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1 · NIST SP 800-30 Rev. 1 · NIST CSF 2.0 · CIS Controls v8.1

Asignación especial de la Semana 2 · Insumo del Proyecto Final

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Qué es un BIA y para qué sirve 3
2. Dónde encaja en la continuidad del negocio 3
3. La salida propia del BIA 4
4. Cómo se construye un BIA, paso a paso 5
5. Caso resuelto: Red Hospitalaria Metropolitana 12
6. Actividad práctica 14
7. El enganche con los marcos y con el Proyecto Final 17
8. Errores frecuentes 17
9. Lo que el estudiante se lleva 18
10. Glosario 19
11. Referencias 19

1. Qué es un BIA y para qué sirve

El análisis de impacto en el negocio responde a una pregunta que ninguna otra herramienta de seguridad responde: cuánto le cuesta a la organización que un proceso deje de funcionar, y durante cuánto tiempo puede soportarlo antes de que el daño sea irreversible. Esta asignación desarrolla el método completo, desde el levantamiento con los dueños de los procesos hasta el informe ejecutivo que la dirección firma, y entrega los insumos que el Proyecto Final necesita para su análisis de riesgos.

El análisis de impacto en el negocio es el proceso de analizar el impacto que una interrupción produce en la organización a lo largo del tiempo, según lo define la norma de sistemas de gestión de la continuidad del negocio **ISO 22301:2019**. La guía específica **ISO/TS 22317:2021**, en su segunda edición, desarrolla el método paso a paso: esa edición cancela y reemplaza la de 2015, se alinea con ISO 22301:2019 y fue confirmada como vigente en la revisión sistemática de 2025. En el ámbito federal estadounidense, la guía de planificación de contingencia **NIST SP 800-34 Rev. 1** sitúa el BIA como el segundo paso de siete de su proceso de planificación.

Para qué sirve, en términos de la dirección

- Sustituye la petición de presupuesto por una cifra de exposición y un plazo de tolerancia que el propio negocio declaró y firmó.
- Ordena la inversión: dice qué se recupera primero y por qué, con un puntaje que otro analista puede reproducir.
- Dimensiona la contingencia: define el personal, los equipos y las instalaciones que la recuperación exige realmente.
- Entrega al análisis de riesgos los dos datos que este necesita y no puede producir por sí mismo: el costo por unidad de tiempo y la criticidad.

2. Dónde encaja en la continuidad del negocio

El lugar del BIA es el comienzo. Dentro del ciclo de continuidad, el BIA y la evaluación de riesgos preceden a la definición de estrategias, y ninguna estrategia de recuperación se elige antes de conocer qué se recupera primero. Elegir primero la tecnología y buscar después el proceso que la justifique invierte el orden y produce planes que protegen lo familiar en lugar de lo esencial.

La lógica secuencial: del impacto al riesgo y del riesgo al control

Tres análisis encadenados sostienen la decisión de invertir en seguridad, y cada uno entrega su resultado al siguiente. El análisis de impacto determina qué procesos importan, con qué urgencia deben volver a operar y cuánto cuesta cada hora de interrupción. El análisis de riesgos toma ese costo, lo combina con la probabilidad de que la amenaza se materialice y produce una pérdida anual esperada. La evaluación de controles compara esa pérdida con el costo de la salvaguarda y decide si la inversión se justifica. Quien salta el primer eslabón termina protegiendo lo que le resulta familiar en lugar de lo que sostiene a la organización.

Análisis	Pregunta que responde	Qué entrega al siguiente
Análisis de impacto en el negocio (BIA)	Qué pasa si el proceso se detiene, y por cuánto tiempo se tolera.	Criticidad, métricas de tiempo, costo por hora y por día, AV, EF y SLE.
Análisis de riesgos (NIST SP 800-30 Rev. 1)	Con qué frecuencia ocurrirá la amenaza.	ARO y ALE: la línea base de riesgo expresada en dinero al año.

Análisis	Pregunta que responde	Qué entrega al siguiente
Evaluación de controles	Si la salvaguarda se paga a sí misma.	Beneficio, ACC y ROSI: la decisión de invertir, con su sensibilidad.

3. La salida propia del BIA

El BIA produce dos resultados que le pertenecen y que ninguna otra actividad entrega. El primero es una lista priorizada de procesos y de los activos que los sostienen, ordenada por criticidad. El segundo es el costo de la interrupción por unidad de tiempo, expresado por hora y por día de indisponibilidad, con las métricas de tiempo que fijan hasta cuándo la organización lo tolera. Todo lo demás —la probabilidad de la amenaza, la pérdida anual, la decisión sobre el control— pertenece a los análisis que vienen después y se alimenta de estos dos resultados.

4. Cómo se construye un BIA, paso a paso

Los trece pasos siguientes son el método completo. Cada uno indica en qué plantilla de la asignación se registra su resultado, de modo que al terminar el paso trece el informe ejecutivo esté completo y sea defendible ante la dirección.

Paso	Qué produce	Plantilla donde se registra
1. Preparar y levantar	Método declarado, participantes y validación firmada.	P02
2. Inventariar los procesos	El universo del análisis.	P01
3. Fijar las métricas de tiempo	MTPD, RTO, WRT, RPO y MBCO, con su comprobación.	P02
4. Valorar el impacto en el tiempo	Matriz de cinco categorías por cinco cortes y el MTPD derivado.	P03
5. Registrar estacionalidad y modo alterno	Peor escenario temporal y duración máxima sostenible.	P02
6. Mapear dependencias	Seis clases, recursos mínimos, puntos únicos de falla e interdependencias.	P04
7. Priorizar	Puntaje de criticidad y lista ordenada de procesos.	P05
8. Cuantificar	Costo por hora y por día, AV, EF y SLE.	P02
9. Cruzar la frontera	Entrega al análisis de riesgos: ARO y ALE.	P07
10. Justificar el control	Cinco pasos, ACC y ROSI.	P07
11. Declarar el método de valoración	Cuantitativo, cualitativo o semicuantitativo, y FAIR como alternativa.	P02 y P06
12. Probar los supuestos	Sensibilidad en escenarios mínimo, esperado y máximo.	P06
13. Redactar el informe ejecutivo	El documento que la dirección lee, discute y firma.	P07

Paso 1 · Preparar el análisis y levantar los datos

Los datos del BIA viven en la cabeza de quien opera el proceso, y el analista los extrae con un método. La entrevista estructurada con el dueño del proceso aporta la profundidad y el matiz. El cuestionario estandarizado permite cubrir muchos procesos con el mismo criterio y hace comparables las respuestas. El taller reúne a las áreas que dependen unas de otras y saca a la luz las interdependencias que nadie declara por separado. La validación con el dueño del proceso cierra cada ficha: quien responde firma lo que respondió. Y la aprobación de la dirección convierte el resultado en la base oficial de la planificación, porque las métricas de tiempo que salen del BIA comprometen presupuesto.

Paso 2 · Inventariar los procesos de negocio

El trabajo empieza por enumerar los procesos, no los sistemas. Un proceso de negocio se describe por lo que produce para alguien: la admisión de un paciente, la emisión de una factura, la entrega de un resultado de laboratorio. Cada entrada del inventario registra el nombre del proceso, el área responsable, el dueño con nombre y cargo, el servicio que entrega, quién lo recibe, los sistemas que lo soportan y su ventana de operación. Este inventario es el universo del análisis: lo que no entra aquí no se analiza, y lo que no se analiza no se protege.

Paso 3 · Fijar las métricas de tiempo

El **período máximo tolerable de interrupción (MTPD**, también llamado **MTD)** es el tiempo tras el cual la interrupción de un proceso produce un daño que la organización ya no puede revertir: pérdida de la licencia de operación, incumplimiento contractual irreparable, fuga masiva de clientes o riesgo para la vida de las personas. Es el límite duro del análisis y lo fija el negocio, nunca el área de tecnología. Todas las demás métricas se acomodan por debajo de él.

El **objetivo de tiempo de recuperación (RTO)** es el plazo máximo para restaurar el proceso y sus sistemas de soporte tras la interrupción. El **tiempo de recuperación del trabajo (WRT)** es el plazo adicional que el personal necesita para reconstruir los datos del período caído, validar la integridad y volver a la operación normal: reintroducir las transacciones registradas en papel, conciliar inventarios, verificar resultados.

> **Comprobación de coherencia que todo BIA debe superar: RTO + WRT ≤ MTPD**
>
> Un RTO de dos horas con un WRT de tres horas sobre un MTPD de cuatro horas deja el proceso operativo una hora después del límite que el negocio declaró irreversible. Si la desigualdad no se cumple, se acorta el RTO, se acorta el WRT o se justifica ante la dirección un MTPD mayor.

El **objetivo de punto de recuperación (RPO)** expresa la cantidad máxima de datos que la organización acepta perder, medida como el intervalo entre el último respaldo utilizable y el momento de la interrupción. Un RPO de cuatro horas significa que el proceso tolera perder hasta cuatro horas de transacciones. El RPO gobierna la frecuencia del respaldo y la tecnología de replicación, mientras el RTO gobierna la capacidad de restauración; son independientes entre sí y se determinan por separado. Un expediente clínico con RPO de quince minutos y un sistema de facturación con RPO de veinticuatro horas conviven en la misma organización.

El **objetivo mínimo de continuidad del negocio (MBCO)** define el nivel reducido de servicio que la organización debe sostener durante la contingencia, mientras la recuperación completa avanza. No todo vuelve a la vez, y el MBCO declara qué parte vuelve primero y con qué capacidad: atender urgencias sin cirugía programada, facturar en modo diferido, operar el veinte por ciento de las cajas. Fijarlo obliga a distinguir entre lo que el proceso hace y lo que el proceso debe hacer para que la organización siga existiendo.

Métrica	Qué mide	Quién la fija	Qué decide en la práctica
MTPD / MTD	Tiempo hasta el daño irreversible.	El negocio.	El límite duro de toda la planificación.
RTO	Plazo para restaurar el proceso y sus sistemas.	El negocio con tecnología.	La arquitectura de recuperación y el sitio alterno.
WRT	Plazo para reconstruir y validar el trabajo del período caído.	El dueño del proceso.	El personal de refuerzo tras la restauración.
RPO	Volumen de datos que se acepta perder, medido en tiempo.	El dueño del proceso.	La frecuencia del respaldo y la replicación.
MBCO	Nivel reducido de servicio durante la contingencia.	La dirección.	Los recursos mínimos que la contingencia exige.

Paso 4 · Valorar el impacto por categoría y en el tiempo

El daño de una interrupción se evalúa en cinco categorías, y cada una se estima por separado antes de consolidarse. El **impacto financiero** cubre la pérdida directa de ingresos, las multas regulatorias, los costos de remediación y las compensaciones a clientes. El **impacto operativo** cubre la detención de la producción, la interrupción de servicios dependientes y la pérdida de productividad del personal. El **impacto legal y regulatorio** cubre el incumplimiento de normativas, las sanciones de las autoridades, la pérdida de certificaciones y las restricciones operativas impuestas. El **impacto reputacional** cubre la pérdida de confianza de los clientes, la cobertura negativa y el deterioro de la marca. Y el **impacto en la seguridad de las personas** cubre el riesgo para la vida y la integridad física: en un hospital, en una planta industrial o en un servicio público esencial, esta categoría manda sobre las otras cuatro y decide por sí sola el orden de recuperación.

El impacto no es constante: crece con la duración de la interrupción, y rara vez lo hace de forma lineal. El BIA evalúa cada categoría en cinco cortes de tiempo —cuatro horas, veinticuatro horas, setenta y dos horas, una semana y un mes— y registra el valor del daño en cada corte. La curva resultante revela el punto de inflexión, que es el momento en que el impacto se dispara. El **umbral de tolerancia** es el nivel de daño que la organización declara inaceptable, y el corte de tiempo en que la curva lo cruza determina el MTPD del proceso. Así el MTPD deja de ser una opinión y pasa a ser el resultado de una medición.

La escala 1–5 de la categoría financiera se ancla en las ventas o ingresos anuales que trae la ficha de datos del cliente del Catálogo (el presupuesto operativo anual en las entidades públicas y sin fines de lucro), de modo que todos los equipos califican con la misma proporción: nivel 1, una pérdida del corte menor que el 0,01 % de ese monto; nivel 2, de 0,01 % a menos de 0,05 %; nivel 3, de 0,05 % a menos de 0,25 %; nivel 4, de 0,25 % a 1 %; y nivel 5, más de 1 %. La sección 3 de BIA_P03 registra el monto de la ficha y los límites en dólares que resultan. En la Red Hospitalaria Metropolitana, con ingresos anuales de USD 62 millones, los límites son USD 6 200, 31 000, 155 000 y 620 000: la pérdida del expediente clínico en el corte de 4 horas, 48 000 dólares, cae en el nivel 3, y la de un día, 288 000 dólares, en el nivel 4. Las otras cuatro categorías se califican con el criterio verbal que el equipo declara para cada nivel, y cuando el criterio monetario y el verbal difieren para un mismo corte se registra el mayor de los dos.

Paso 5 · Registrar la estacionalidad y el procedimiento alterno

El mismo proceso interrumpido produce daños distintos según el momento del año en que ocurra. La facturación de un supermercado cae de forma muy distinta un martes de febrero que la víspera de Navidad; la admisión hospitalaria cambia durante un brote estacional; la nómina concentra su criticidad en dos días de cada mes. El BIA registra los períodos pico de cada proceso y evalúa el impacto en el peor escenario temporal, porque la planificación de continuidad se dimensiona para el peor caso y no para el promedio.

Muchos procesos tienen una forma manual de seguir operando cuando el sistema cae: el registro en papel, la autorización telefónica, la hoja de cálculo local. El BIA documenta esos procedimientos alternos con precisión —qué se hace, quién lo hace, qué recursos exige— y añade el dato que suele faltar: la **duración máxima sostenible**, es decir cuántas horas o días puede la organización operar así antes de que el volumen acumulado desborde al personal, la calidad se degrade o la reconstrucción posterior se vuelva impracticable. Esa duración es la que alarga el MTPD del proceso, y por eso se declara y se verifica.

Paso 6 · Mapear las dependencias y los recursos mínimos

Ningún proceso opera solo. El BIA levanta seis clases de dependencia por cada proceso, y es la parte del análisis que más hallazgos produce, porque expone compromisos que nadie había escrito.

Clase de dependencia	Qué se registra de ella
Personas y competencias críticas	Quién sabe hacerlo y cuántas personas comparten ese conocimiento.
Aplicaciones y sistemas	Las plataformas que soportan el proceso y su modo de acceso.
Datos y registros vitales	Su ubicación, su formato y su respaldo.
Proveedores y terceros	El servicio que prestan y su propio compromiso de nivel de servicio.
Instalaciones	Dónde ocurre físicamente el trabajo.
Equipamiento y servicios básicos	Energía, climatización, conectividad y agua.

De cada dependencia el análisis extrae dos cosas. La primera es el **recurso mínimo requerido en la recuperación**: cuántas personas, cuántas estaciones de trabajo, qué capacidad de red y qué instalación se necesitan para operar en el nivel del MBCO, que es siempre menor que el requerimiento de la operación normal. La segunda es el **punto único de falla**: la dependencia sin alternativa, cuya caída detiene el proceso por completo. Una sola persona que conoce el procedimiento, un único proveedor de un insumo, un enlace sin respaldo, un servidor sin réplica. Cada punto único de falla identificado se registra con su proceso y pasa al informe ejecutivo, porque suele ser el hallazgo más barato de corregir y el más caro de ignorar.

Los procesos también dependen unos de otros, y esa red condiciona el orden de recuperación. Si la facturación necesita los datos de la admisión, recuperar la facturación primero no produce ningún servicio. El BIA documenta, por cada proceso, cuáles lo alimentan y cuáles se alimentan de él, y con ello construye la secuencia de recuperación. Una consecuencia útil aparece de inmediato: un proceso de criticidad media que alimenta a tres procesos críticos hereda la urgencia de aquellos a los que sostiene.

Paso 7 · Priorizar con un puntaje explícito

La priorización se resuelve con un puntaje explícito y reproducible, no con una discusión. Cada proceso recibe una calificación en cada categoría de impacto, evaluada en el mismo corte para todos: la convención del proyecto es el corte de 24 horas, porque el del MTPD más corto aplana a los procesos que toleran horas y no días; cada categoría lleva un peso acordado con la dirección; y el puntaje de criticidad es la suma ponderada multiplicada por (1 + 0,10 × número de procesos que dependen de él), redondeada a dos decimales con la mitad hacia arriba. El resultado ordena todos los procesos en una lista única y clasifica cada uno como crítico, importante o diferible. Que el método sea explícito importa más que su sofisticación: hace la decisión auditable y permite que otro analista, con los mismos datos, llegue al mismo resultado.

La precalificación ordena el trabajo. El inventario de BIA_P01 recoge todo el censo; cada proceso se precalifica en BIA_P05 en el corte de 24 horas con las consecuencias que la ficha de datos del cliente trae para ese corte, y solo los que resultan críticos llevan ficha BIA_P02, matriz BIA_P03 y mapa BIA_P04 completos. Los importantes y diferibles conservan su fila en BIA_P01 y en BIA_P05; el proceso importante que trata los datos personales que la ficha cuantifica lleva además la valoración de BIA_P02 para su pérdida por exposición de datos. Un proceso crítico por la confidencialidad de sus datos que puntúa bajo en disponibilidad conserva la clase de su puntaje: esa criticidad se registra como brecha en BIA_P06 y pasa como riesgo al análisis de riesgos.

Paso 8 · Cuantificar: valor del activo, exposición y costo por unidad de tiempo

El **valor del activo (AV)** es el valor económico total del activo o del proceso analizado, e incluye el costo de reposición, el valor de la información que contiene y el flujo que genera. El **factor de exposición (EF)** es la

proporción de ese valor que se pierde cuando el evento adverso ocurre, expresada como porcentaje entre cero y uno. Un incendio que destruye un centro de datos tiene un factor de exposición cercano a uno; un ataque de denegación de servicio que interrumpe una plataforma durante cuatro horas tiene un factor mucho menor. Ambos valores se estiman, y por eso el BIA exige declarar el supuesto detrás de cada uno.

SLE = AV × EF

La **pérdida esperada por un evento único (SLE)** responde a cuánto cuesta una vez que el evento ocurra, sin decir nada sobre cuántas veces ocurrirá. Un proceso con un valor de doscientos mil dólares y un factor de exposición de cuarenta por ciento arroja una pérdida de ochenta mil dólares por evento. Esta cifra es el puente entre el BIA y el análisis de riesgos: el BIA la produce, y el análisis de riesgos la usa.

Un mismo proceso puede tener más de un escenario —cifrado o indisponibilidad, exposición de datos, fraude, sabotaje de la operación—, y cada escenario tiene su propio factor de exposición y su propia pérdida por evento único, con un identificador que el análisis de riesgos cita.

La métrica más característica del BIA es el **costo de la indisponibilidad por unidad de tiempo**. Se construye sumando, para cada hora de interrupción, los ingresos que dejan de percibirse, el costo del personal que permanece improductivo o en horas extra, las penalizaciones contractuales que se activan y el costo de las medidas alternas. Multiplicada por la duración esperada de la interrupción, da el impacto del escenario; comparada entre procesos, ordena la inversión. Cuando la dirección pregunta qué se gana con la inversión en continuidad, esta es la cifra que responde.

Paso 9 · Dónde termina el BIA y dónde empieza el análisis de riesgos

Esta frontera es el punto que más se confunde en la práctica profesional, y conviene decirlo sin rodeos. El BIA entrega el costo de la interrupción por unidad de tiempo, las métricas de tiempo, la criticidad y el valor del activo con su factor de exposición, de donde sale la pérdida por evento único. La **tasa anualizada de ocurrencia (ARO)** y la **pérdida anual esperada (ALE)** pertenecen a la evaluación cuantitativa de riesgos, tal como la describe la guía de conducción de evaluaciones de riesgo **NIST SP 800-30 Rev. 1**, porque ambas requieren estimar la probabilidad de la amenaza, y la probabilidad queda fuera del alcance del BIA. El BIA responde qué pasa si ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

ALE = SLE × ARO · pertenece al análisis de riesgos, no al BIA

La tasa anualizada de ocurrencia expresa cuántas veces se espera que el evento ocurra en un año, y admite valores menores que uno: un evento esperado una vez cada cinco años tiene una tasa de cero coma dos. Con una pérdida de ochenta mil dólares por evento y una tasa de cero coma cinco, la pérdida anual esperada es de cuarenta mil dólares. Esa cifra anual es la que se compara contra el costo anual de un control, y por eso el análisis de riesgos la necesita antes de decidir nada.

Pertenece al BIA	Pertenece al análisis de riesgos
Criticidad y lista priorizada de procesos	Tasa anualizada de ocurrencia (ARO)
MTPD, RTO, WRT, RPO y MBCO	Pérdida anual esperada (ALE = SLE × ARO)
Costo de indisponibilidad por hora y por día	Probabilidad de la amenaza y su fundamento
Valor del activo (AV) y factor de exposición (EF)	Comparación del riesgo contra el apetito declarado

Pérdida por evento único (SLE = AV × EF)	Selección y justificación económica del control

Paso 10 · Justificar el control: cinco pasos, ACC y ROSI

La decisión de invertir se resuelve en cinco pasos. Primero se calcula la pérdida anual esperada sin control adicional, que es la línea base del riesgo. Segundo se estima la efectividad del control propuesto, expresada como el porcentaje en que reduce la pérdida por evento o la frecuencia, apoyada en especificaciones técnicas y en estudios, no en la impresión del vendedor. Tercero se calcula la pérdida anual esperada con el control operando. Cuarto se determina el beneficio como la diferencia entre ambas cifras. Y quinto se calculan los costos totales del control. La inversión se justifica cuando el beneficio supera al costo.

El **costo anual del control (ACC)** reúne todos los gastos recurrentes asociados a implantar y sostener la contramedida, y se agrupa en tres familias. Los **costos de adquisición**: licencias de software anualizadas, hardware y equipamiento, y el costo de la implementación inicial repartido sobre su vida útil. Los **costos operacionales**: las horas de personal dedicadas a la gestión, el monitoreo y la administración, y el consumo de recursos computacionales. Los **costos de mantenimiento**: actualizaciones y parches, soporte técnico y capacitación continua del personal. Omitir cualquiera de las tres familias infla el retorno aparente y produce decisiones que el presupuesto desmiente al año siguiente.

ROSI = (Beneficio − ACC) ÷ ACC

El **retorno de la inversión en seguridad (ROSI)** expresa en porcentaje la eficiencia de la inversión: se resta el costo anual del control al beneficio obtenido, y el resultado se divide entre ese mismo costo. Un control que reduce la pérdida anual esperada en cuarenta mil dólares y cuesta quince mil al año produce un beneficio neto de veinticinco mil y un retorno del ciento sesenta y siete por ciento. El indicador permite comparar controles entre sí y ordenar el gasto, y su valor depende por completo de la calidad de las estimaciones que lo alimentan, lo que devuelve la atención al rigor del BIA que está en su origen.

Paso 11 · Elegir el método de valoración

El **método cuantitativo** asigna valores monetarios y produce cifras comparables y defendibles ante la dirección, a costa de exigir datos históricos que muchas organizaciones no tienen. El **método cualitativo** clasifica el impacto en escalas verbales —alto, medio, bajo— y resulta rápido y aplicable con poca información, a costa de que dos analistas obtengan resultados distintos sobre el mismo caso. El **método semicuantitativo** asigna valores numéricos a las categorías cualitativas y permite ordenar y ponderar conservando la simplicidad, con la advertencia de que esos números conservan la naturaleza ordinal de su origen y no admiten aritmética como si fueran dinero. Cuando faltan datos históricos, el analista declara el supuesto, documenta su fuente y lo somete al análisis de sensibilidad.

FAIR: cuantificar con rangos en lugar de valores puntuales

El análisis factorial del riesgo de la información —FAIR— es una taxonomía de riesgo publicada por **The Open Group** en sus normas Open FAIR: la de taxonomía **Risk Taxonomy (O-RT) versión 3.0.1** y la de análisis **Risk Analysis (O-RA) versión 2.0.1**, ambas publicadas en noviembre de 2021 con las referencias C20B y C20A y vigentes como cuerpo de conocimiento de la certificación Open FAIR. Su aporte metodológico es descomponer el riesgo en dos ramas: la frecuencia de los eventos de pérdida y la magnitud de la pérdida, y esta última en **pérdida primaria** —la que sufre la organización de forma directa— y **pérdida secundaria** —la que proviene de la reacción de terceros: multas, litigios, respuesta de los clientes—. A diferencia del esquema de pérdida por evento, tasa anualizada y pérdida anual, que trabaja con valores puntuales, FAIR trabaja con rangos y distribuciones de probabilidad, lo que encaja precisamente

cuando los datos históricos escasean, que es la situación de las empresas del catálogo del Proyecto Final. Se enseña como alternativa disponible, y el criterio profesional consiste en saber cuándo conviene cada uno.

Paso 12 · Someter los supuestos al análisis de sensibilidad

Todo BIA descansa en estimaciones, y una conclusión que solo se sostiene con la estimación más optimista no es una conclusión. El análisis de sensibilidad exige tres cosas. Declarar cada supuesto con su origen y su fecha. Variarlo en tres escenarios —mínimo, esperado y máximo— para el valor del activo, el factor de exposición y la tasa anualizada de ocurrencia. Y observar cuánto se mueve el resultado con cada variación, lo que identifica las variables que gobiernan la conclusión. La regla de decisión es directa: si la recomendación se mantiene en los tres escenarios, es robusta y se presenta como tal; si cambia de signo al variar un solo supuesto, la recomendación depende de ese supuesto y el informe ejecutivo debe decirlo con esas palabras. El registro de supuestos es donde vive esta evidencia.

Paso 13 · Redactar el informe ejecutivo

El informe ejecutivo es el producto que la dirección lee, discute y firma, y es el único artefacto del análisis que la mayoría de los directivos verá. Se escribe para quien decide el presupuesto, no para quien opera el sistema: la exposición se expresa en dinero por unidad de tiempo, el plazo se expresa en horas que el propio negocio declaró, y cada recomendación llega con su costo y con la decisión que se solicita.

Sección del informe	Qué contiene
Resumen ejecutivo	Una página: exposición en dinero por unidad de tiempo, plazo de tolerancia, hallazgos que exigen decisión y recomendación con su costo.
Alcance y método	Procesos incluidos y excluidos con su razón, período, medios de levantamiento, participantes y método de valoración.
Procesos priorizados	Lista ordenada con su clase y sus métricas de tiempo, con la comprobación RTO + WRT ≤ MTPD superada en todas las fichas.
Costo de la indisponibilidad	Costo por hora, por día y al alcanzar el MTPD, con el supuesto principal de cada cifra.
Puntos únicos de falla y brechas	Hallazgo, proceso afectado, consecuencia, acción propuesta y costo estimado.
Frontera con el análisis de riesgos	Qué entrega el BIA y qué corresponde al análisis de riesgos, declarado de forma explícita.
Justificación del control	Los cinco pasos, el ACC con sus tres familias y el ROSI.
Análisis de sensibilidad	Escenarios mínimo, esperado y máximo, y conclusión sobre la robustez de la recomendación.
Recomendaciones y aprobación	Decisión solicitada a la dirección y firmas.

5. Caso resuelto: Red Hospitalaria Metropolitana

El caso recorre el método completo sobre una empresa del catálogo del Proyecto Final, en los tres pasos que enseñan la frontera entre el BIA y el análisis de riesgos por la vía de cruzarla. Todas las cifras del caso son supuestos declarados del ejercicio, tomados del perfil del catálogo, y se someten al análisis de sensibilidad del paso tres.

Paso 1 · El BIA

La Red Hospitalaria Metropolitana opera un hospital en San Salvador y tres clínicas especializadas, con novecientos cincuenta empleados y cuatro procesos críticos declarados. El análisis toma el primero de ellos, la gestión del expediente clínico electrónico. La categoría que domina no es la financiera: la indisponibilidad del expediente obliga al personal médico a decidir sin historial de alergias, medicación previa ni resultados, y eso sitúa el impacto en seguridad de las personas en el nivel máximo desde la primera hora.

Resultado del levantamiento	Valor declarado
MTPD — período máximo tolerable de interrupción	4 horas
RTO — objetivo de tiempo de recuperación	2 horas
WRT — tiempo de recuperación del trabajo	2 horas adicionales para reintroducir lo registrado en papel
Comprobación RTO + WRT ≤ MTPD	2 + 2 = 4 ≤ 4 · cumple en el límite
RPO — objetivo de punto de recuperación	15 minutos
MBCO — objetivo mínimo de continuidad	Atender urgencias con registro en papel, sin cirugía programada
Procedimiento alterno	Registro en papel, con duración máxima sostenible de 8 horas
Puntos únicos de falla	Segmentación laxa entre la red administrativa y la médica; ausencia de inventario de los dispositivos médicos conectados
Costo de la indisponibilidad	12 000 dólares por hora: cirugías programadas canceladas, personal improductivo y costo del procedimiento alterno
Clase y fichas	Crítico en la precalificación de BIA_P05, calificado en el corte de 24 horas con las consecuencias que trae la ficha; por ser crítico lleva ficha completa, matriz de impacto y mapa de dependencias (regla única de fichas)

Paso 2 · Del BIA al análisis cuantitativo de riesgo

Aquí termina el BIA y empieza el análisis de riesgos. El escenario que se evalúa es el cifrado del entorno del expediente clínico por un ataque de secuestro de datos que aprovecha la segmentación laxa. El valor del proceso se establece en ochocientos mil dólares, y el factor de exposición en cero coma cinco, porque el respaldo permite recuperar la mitad del valor sin pagar rescate ni reconstruir desde cero. Hasta aquí, todo salió del BIA. El paso siguiente introduce la probabilidad, que el BIA no aporta.

Variable	Valor	Origen
AV — valor del proceso	800 000 dólares	BIA
EF — factor de exposición	0,5	BIA
SLE = AV × EF	400 000 dólares	BIA

Variable	Valor	Origen
ARO — tasa anualizada de ocurrencia	0,4, estimada a partir de la exposición del sector salud y de la madurez baja de controles que el catálogo declara	Análisis de riesgos
ALE = SLE × ARO	160 000 dólares al año	Análisis de riesgos

Esa cifra anual es la línea base contra la que se mide cualquier control.

El mismo método admite un SLE por escenario, cada uno con su EF y su identificador SLE-nn. En «Admisión y facturación», proceso importante que trata los datos personales de los 310 000 pacientes con expediente clínico que cuantifica la ficha, la exposición de toda la base vale 310 000 × 0,40 dólares de notificación a cada paciente = 124 000 dólares y, con EF 1, el SLE es de 124 000 dólares. La matriz de riesgos cita en cada riesgo el SLE del escenario que le corresponde.

Paso 3 · Evaluar el control y decidir

El control propuesto combina la segmentación efectiva de la red médica con el inventario y monitoreo de los dispositivos conectados, que son las dos brechas que el BIA expuso. Su efectividad estimada reduce la tasa anualizada de ocurrencia de cero coma cuatro a cero coma quince.

Paso de la justificación	Cálculo	Resultado
1. ALE actual, sin control adicional	400 000 × 0,4	160 000 dólares al año
2. Efectividad del control	ARO baja de 0,4 a 0,15	Reducción de la frecuencia
3. ALE con el control operando	400 000 × 0,15	60 000 dólares al año
4. Beneficio	160 000 − 60 000	100 000 dólares al año
5. Costo anual del control (ACC)	Adquisición anualizada, operación y mantenimiento	45 000 dólares al año
Beneficio neto	100 000 − 45 000	55 000 dólares al año
ROSI = (Beneficio − ACC) ÷ ACC	55 000 ÷ 45 000	122 %

El análisis de sensibilidad cierra la decisión: variando la tasa anualizada entre cero coma dos y cero coma seis, el beneficio neto se mantiene positivo en los tres escenarios, de modo que la recomendación es robusta y no depende del supuesto más favorable.

Escenario	ARO	ALE actual	ALE con control	Beneficio	Beneficio neto (ACC 45 000)
Mínimo	0,2	80 000	30 000	50 000	5 000
Esperado	0,4	160 000	60 000	100 000	55 000
Máximo	0,6	240 000	90 000	150 000	105 000

6. Actividad práctica

6.1 Ejercicio guiado, con solución publicada

El ejercicio se resuelve sobre el mismo proceso del caso —la gestión del expediente clínico electrónico de la Red Hospitalaria Metropolitana— con un escenario distinto: la falla del almacenamiento primario, que no tiene réplica. Las cifras son supuestos declarados del ejercicio. Resolver antes de leer la solución.

Dato del ejercicio	Valor
MTPD declarado por la Dirección Médica	4 horas
RTO que propone el área de tecnología	3 horas
WRT estimado por el dueño del proceso	2 horas
Costo de indisponibilidad	12 000 dólares por hora
AV — valor del proceso	800 000 dólares
EF — factor de exposición del escenario	0,25
ARO estimada por el análisis de riesgos	0,3
Control propuesto	Réplica sincrónica del almacenamiento con pruebas periódicas de restauración
Efectividad del control	Reduce el factor de exposición de 0,25 a 0,10
ACC del control	20 000 dólares al año: 9 000 de adquisición, 7 000 de operación y 4 000 de mantenimiento

Se pide: (a) verificar la coherencia de las métricas de tiempo y corregirla si falla; (b) calcular el costo de la indisponibilidad por día y al alcanzar el MTPD; (c) calcular el SLE; (d) calcular el ALE y decir a qué análisis pertenece; (e) evaluar el control en los cinco pasos y obtener el ROSI; (f) someter la conclusión al análisis de sensibilidad con una tasa anualizada de 0,2 y de 0,4.

6.2 Solución

(a) Coherencia de las métricas. RTO 3 h + WRT 2 h = 5 h, que excede el MTPD de 4 h. La ficha no avanza con esos valores. La corrección que el caso admite es llevar el RTO a 2 horas, con lo que 2 + 2 = 4 ≤ 4 y la comprobación se cumple en el límite. La alternativa sería reducir el WRT, lo que exige personal de refuerzo para la reconstrucción, o justificar ante la dirección un MTPD mayor, que en un expediente clínico no procede porque la categoría que manda es la seguridad de las personas.

(b) Costo de la indisponibilidad. Por hora, 12 000 dólares. Por día, 12 000 × 24 = 288 000 dólares. Al alcanzar el MTPD de 4 horas, 12 000 × 4 = 48 000 dólares. La cifra del MTPD es la que se lleva al informe ejecutivo, porque es la pérdida que la organización ya declaró intolerable.

(c) Pérdida por evento único. SLE = AV × EF = 800 000 × 0,25 = **200 000 dólares**. Es la última cifra que produce el BIA.

(d) Pérdida anual esperada. ALE = SLE × ARO = 200 000 × 0,3 = **60 000 dólares al año**. Pertenece al análisis de riesgos, no al BIA, porque incorpora la probabilidad de la amenaza. El BIA aportó el SLE; la tasa anualizada vino de la evaluación de riesgos conforme a NIST SP 800-30 Rev. 1.

(e) Evaluación del control en cinco pasos.

Paso	Cálculo	Resultado
1. ALE actual	200 000 × 0,3	60 000 dólares al año
2. Efectividad	EF baja de 0,25 a 0,10, con lo que el SLE pasa a 800 000 × 0,10	SLE con control: 80 000 dólares
3. ALE con el control	80 000 × 0,3	24 000 dólares al año
4. Beneficio	60 000 − 24 000	36 000 dólares al año
5. ACC	9 000 + 7 000 + 4 000	20 000 dólares al año
Beneficio neto	36 000 − 20 000	16 000 dólares al año
ROSI	16 000 ÷ 20 000	**80 %**

(f) Análisis de sensibilidad. Se varía la tasa anualizada dejando fijos el valor del activo y la efectividad del control.

Escenario	ARO	ALE actual	ALE con control	Beneficio	Beneficio neto	ROSI
Mínimo	0,2	40 000	16 000	24 000	4 000	20 %
Esperado	0,3	60 000	24 000	36 000	16 000	80 %
Máximo	0,4	80 000	32 000	48 000	28 000	140 %

El beneficio neto se mantiene positivo en los tres escenarios, de modo que la recomendación es robusta y el informe la presenta como tal. Conviene notar el margen del escenario mínimo: con una tasa de 0,2 el retorno cae al veinte por ciento, y una desviación al alza del ACC de apenas cuatro mil dólares anularía el beneficio. Ese dato se declara en el informe, porque una recomendación robusta con margen estrecho exige controlar el costo del control tanto como su efectividad.

6.3 Trabajo del equipo, sobre su propia empresa

Cada equipo toma su empresa del catálogo del Proyecto Final con su ficha de datos del cliente, inventaría en BIA_P01 todos los procesos del alcance, los precalifica en BIA_P05 en el corte de 24 horas y recorre el método completo en cada proceso que resulta crítico. Levanta la ficha de cada uno con sus cinco categorías de impacto evaluadas en los cinco cortes de tiempo, deriva el MTPD del cruce con el umbral de tolerancia, fija RTO, WRT, RPO y MBCO comprobando que la suma de RTO y WRT no exceda el MTPD, mapea las seis clases de dependencia, identifica al menos dos puntos únicos de falla, calcula el costo de indisponibilidad por hora y por día, y estima el valor del activo, el factor de exposición y la pérdida por evento único. Después cruza la frontera: propone una tasa anualizada de ocurrencia con su justificación, calcula la pérdida anual esperada, evalúa un control con su costo anual y su retorno, y somete la conclusión al análisis de sensibilidad en tres escenarios. El resultado se entrega en las plantillas de la asignación y se resume en el informe ejecutivo. En el Proyecto Final, el cruce de la frontera —pasos 9 y 10: tasa anualizada, pérdida anual esperada, control y retorno— se completa en E.05: el informe BIA_P07 se entrega en el hito H2 con sus secciones 8 a 11 marcadas «se completa en E.05» y se actualiza a la versión 1.1 junto con E.05.

Entregable	Plantilla
Inventario de procesos de la empresa	BIA_P01_Inventario_Procesos
Ficha BIA de cada proceso crítico	BIA_P02_Ficha_BIA_Proceso

Entregable	Plantilla
Matriz de impacto de cada proceso crítico, por categoría y corte de tiempo	BIA_P03_Matriz_Impacto_Tiempo
Mapa de dependencias y recursos mínimos de cada proceso crítico	BIA_P04_Mapa_Dependencias_Recursos
Precalificación del censo, matriz de criticidad y lista priorizada	BIA_P05_Matriz_Criticidad_Priorizacion
Registro de supuestos, puntos únicos de falla y brechas	BIA_P06_Registro_Supuestos_SPOF_Brechas
Informe ejecutivo	BIA_P07_Informe_Ejecutivo

7. El enganche con los marcos y con el Proyecto Final

Los resultados del BIA se conectan con los marcos que el curso utiliza. En el marco de ciberseguridad **NIST CSF 2.0**, alimentan la función de gobernar con el apetito de riesgo declarado por la dirección, la función de identificar con la priorización de activos y procesos, y la función de recuperar con los objetivos de tiempo que la planificación debe cumplir. En los **controles CIS v8.1**, el inventario de dependencias sostiene los controles de inventario de activos empresariales y de software, y la protección de los datos y registros vitales sostiene el control de recuperación de datos. Dentro del Proyecto Final, el BIA que cada equipo produce alimenta la matriz de riesgos de E.05 y sustenta el orden de implantación de las salvaguardas del IG asignado dentro del roadmap de E.10.

Ubicación en el Proyecto Final. El BIA es el entregable **E.03** de la Guía del Estudiante del Proyecto Final y se entrega en el hito H2 (S4). El paquete de entrega es la hoja de consolidación E03_BIA_Consolidacion_Procesos_Criticos.docx (tabla de procesos críticos ordenados por criticidad con MTPD, RTO, WRT, RPO y costo por hora, y tabla de puntos únicos de falla) más las siete plantillas BIA_P01–P07 como anexos obligatorios. La consolidación toma la criticidad de BIA_P05, el costo por hora de BIA_P07 y los puntos únicos de falla de BIA_P06; la matriz de riesgos de E.05 continúa desde ahí con ARO y ALE, tal como el caso de RHM lo muestra en su Paso 2. El método de esta guía es el método oficial del proyecto.

8. Errores frecuentes

Error	Por qué falla	Qué hacer en su lugar
Inventariar sistemas en lugar de procesos	El daño se mide sobre lo que la organización entrega a alguien, no sobre la infraestructura.	Nombrar el proceso con un verbo y su objeto, y anotar el sistema como dependencia.
Que el área de tecnología fije el MTPD	El límite tras el cual el daño es irreversible lo conoce el negocio, no quien opera el servidor.	Levantar el MTPD con el dueño del proceso y hacerlo aprobar por la dirección.
Olvidar el WRT	Restaurar el sistema no equivale a tener el proceso operando: falta reconstruir el trabajo del período caído.	Aplicar siempre la comprobación RTO + WRT ≤ MTPD antes de cerrar la ficha.
Confundir RTO con RPO	Gobiernan cosas distintas: uno la capacidad de restauración y el otro la frecuencia del respaldo.	Determinarlos por separado, con su propia justificación.
Calcular el ALE dentro del BIA	La probabilidad de la amenaza queda fuera del alcance del BIA.	Entregar el SLE y dejar el ARO y el ALE al análisis de riesgos.
Estimar el impacto en un solo momento del año	La planificación se dimensiona para el peor escenario temporal.	Registrar los períodos pico y valorar sobre el peor caso.
Suponer que el modo alterno aguanta indefinidamente	El volumen acumulado desborda al personal y la reconstrucción posterior se vuelve impracticable.	Declarar y verificar la duración máxima sostenible.
Omitir familias de gasto en el ACC	Infla el retorno aparente y el presupuesto lo desmiente al año siguiente.	Sumar adquisición, operación y mantenimiento, las tres.
Presentar una sola cifra sin supuestos	Una conclusión que solo se sostiene con la estimación más optimista no es una conclusión.	Declarar cada supuesto y variarlo en tres escenarios.
Hacer aritmética con escalas cualitativas	Los números semicuantitativos conservan la naturaleza ordinal de su origen.	Usarlos para ordenar y ponderar, no como si fueran dinero.

9. Lo que el estudiante se lleva

Un análisis de impacto en el negocio bien hecho cambia la conversación con la dirección, porque sustituye la petición de presupuesto por una cifra de exposición y un plazo de tolerancia que el propio negocio declaró y firmó. El método que esta asignación desarrolla es el mismo que se aplica en un banco, en un hospital, en un operador logístico o en una institución pública: enumerar los procesos, medir el impacto en el tiempo, mapear las dependencias, priorizar con un puntaje explícito, poner precio a la hora de indisponibilidad, y entregar ese resultado al análisis de riesgos sabiendo con precisión dónde termina la responsabilidad de cada análisis. El rigor del método vive en los supuestos declarados y en la sensibilidad que los pone a prueba.

10. Glosario

Término	Definición
ACC — Annual Cost of Control	Costo anual del control: suma de los gastos de adquisición, operación y mantenimiento de la contramedida.
ALE — Annual Loss Expectancy	Pérdida anual esperada, igual a SLE × ARO. Pertenece al análisis de riesgos.
ARO — Annualized Rate of Occurrence	Tasa anualizada de ocurrencia: veces que se espera que el evento ocurra en un año. Admite valores menores que uno.
AV — Asset Value	Valor del activo o del proceso: costo de reposición, valor de la información y flujo que genera.
BIA — Business Impact Analysis	Análisis de impacto en el negocio: proceso de analizar el impacto que una interrupción produce en la organización a lo largo del tiempo (ISO 22301:2019, 3.5).
EF — Exposure Factor	Factor de exposición: proporción del valor del activo que se pierde cuando el evento ocurre, entre 0 y 1.
FAIR — Factor Analysis of Information Risk	Taxonomía de riesgo de The Open Group que trabaja con rangos y distingue pérdida primaria y secundaria.
MBCO — Minimum Business Continuity Objective	Objetivo mínimo de continuidad: nivel reducido de servicio sostenido durante la contingencia.
MTPD / MTD	Período máximo tolerable de interrupción: tiempo tras el cual el daño es irreversible. Lo fija el negocio.
Punto de inflexión	Corte de tiempo a partir del cual el impacto de la interrupción crece de forma abrupta.
ROSI — Return on Security Investment	Retorno de la inversión en seguridad, igual a (Beneficio − ACC) ÷ ACC, expresado en porcentaje.
RPO — Recovery Point Objective	Objetivo de punto de recuperación: cantidad máxima de datos que se acepta perder, medida en tiempo.
RTO — Recovery Time Objective	Objetivo de tiempo de recuperación: plazo máximo para restaurar el proceso y sus sistemas de soporte.
SLE — Single Loss Expectancy	Pérdida esperada por evento único, igual a AV × EF. Es la última cifra que produce el BIA.
SPOF — Single Point of Failure	Punto único de falla: dependencia sin alternativa cuya caída detiene el proceso por completo.
Umbral de tolerancia	Nivel de daño que la organización declara inaceptable; el corte en que se cruza determina el MTPD.
WRT — Work Recovery Time	Tiempo de recuperación del trabajo: plazo adicional para reconstruir los datos del período caído y validar su integridad.

11. Referencias

- **ISO 22301:2019** — Seguridad y resiliencia. Sistemas de gestión de la continuidad del negocio. Requisitos.
- **ISO/TS 22317:2021** — Seguridad y resiliencia. Sistemas de gestión de la continuidad del negocio. Directrices para el análisis de impacto en el negocio. Segunda edición, noviembre de 2021; cancela y reemplaza la edición de 2015 y fue confirmada como vigente en la revisión sistemática de 2025.

- **NIST SP 800-34 Rev. 1** — Contingency Planning Guide for Federal Information Systems. Sitúa el BIA como el segundo paso de siete del proceso de planificación.
- **NIST SP 800-30 Rev. 1** — Guide for Conducting Risk Assessments. Marco de la evaluación cuantitativa de riesgos, de donde provienen el ARO y el ALE.
- **NIST CSF 2.0** (2024) — Cybersecurity Framework. Funciones de gobernar, identificar y recuperar.
- **CIS Controls v8.1** (2024) — Controles de inventario de activos empresariales y de software, y de recuperación de datos.
- **The Open Group** — Risk Taxonomy (O-RT) Standard, versión 3.0.1 (C20B, noviembre de 2021) y Risk Analysis (O-RA) Standard, versión 2.0.1 (C20A, noviembre de 2021).

Guía derivada del storyboard SD_BIA de la asignación, con el que mantiene congruencia campo a campo. Toda cifra del caso y del ejercicio es un supuesto declarado, tomado del perfil del catálogo del Proyecto Final.